

MEDICARE CONNECT (PTY) LTD INCIDENT RESPONSE PLAN

Aligned to ISO 27035:2023 and POPIA Section 22

Classification: Confidential

Version: 1.0

Date: March 2026

Author: Patrick Mohlala, GRC Analyst

Approved by: [Pending – CEO]

Review Date: March 2027

1. PURPOSE

This Incident Response plan defines how Medicare Connect , detects , responds to, contains and recovers from information security incidents affecting patients data, clinical systems and daily operations.

It ensures the organisation meets its obligations under :

- POPIA Section 22 (72-Hour notification)
- ISO 27001:2022 Annex A.5.24 to A.5.28
- ISO 27035:2023 (Incident Management)
- National Health Act 6 of 2003

2. SCOPE

This Plan applies to :

- All information systems within the ISMS
- All 45 Medicare Connect staff members
- All third-party providers with the system access
- All incident types from tier 1 to tier 4

3. BUSINESS PROBLEM THIS PLAN SOLVES

Risk Register item , Risk -005 scored Critical (20/25) :

Medicare Connect processes approximately 12.000 patient medical records with no documented procedure for what to do when something goes wrong.

Under POPIA Section 22 the organization has 72 hours to notify the Information regulator after discovering a breach.

Without this plan that clock runs out before anyone agrees who makes the first phone call. A recoverable incident becomes a regulatory enforcement matter with fines up to R10 Million.

4. INCIDENT RESPONSE TEAM

- Role : Incident Response Manager
- Person : IT Manager

Responsibilities :

- Declare and classify the incident
 - Coordinate technical response
 - Brief CEO and Information Security
 - Make containment decisions
 - Authorize evidence collection
 - Contact : 071 258 1020
-

- Role : Information Officer (POPIA Lead)
- Person : Appointed Information Officer

Responsibilities :

- Assess POPIA reputability
 - Prepare and submit Information regulator notification
 - Coordinate affected person notification
 - Maintain POPIA breach register
 - Contact : 074 254 5869
-

- Role : GRC Analyst
- Person : Patrick Mohlala

Responsibilities :

- Document all the action and timeline
 - Maintain chain of custody for evidence
 - track POPIA notification deadlines
 - Prepare post - incident review report
 - Update risk register and controls
 - Contact : 073 977 9671
-

- Role : CEO
- Person : Chief Executive

Responsibilities :

- Ultimate decision authority
 - Approve regulatory notification
 - Media and board communication
 - approve external support spend
 - Contact : 084 1024 587
-

- Role : Clinical Lead
- Person : Senior Doctor / Practice Manager

Responsibilities:

- Activate clinical continuity procedures
 - Maintain patient safety during incident
 - Approve patient-facing communications
- Contact: 078 465 5854
-

EXTERNAL SUPPORT

- Cyber Insurer : [Policy number and hotline]
- Legal Counsel : [Attorney contact]
- Forensic IR Firm : [Vendor contact]
- Microsoft Support : [M365 admin portal]
- Information Regulator : inforegulator@inforegulator.org.za | 012 406 4818
- SAPS (stolen devices) : 10111

5. THE SIX PHASES OF INCIDENT RESPONSE

Phase 1

- Preparation (before any incident)
- This IR plan documented and approved
- IR team trained and contacts confirmed
- Classification guide distributed to all staff

- All staff trained to report incidents
- Emergency contact list printed and stored offline
- Cyber insurance policy active
- Forensic IR vendor pre-contracted
- Backups tested and verified restorable
- Legal counsel retained and briefed
- POPIA Form 4 template pre-populated with company details
- Information Regulator portal access confirmed
- Tabletop exercise conducted at least annually

Phase 2 – Detection And Reporting

How incidents are detected:

- Staff report to IT Manager
- Automated security tool alerts
- Patient or third-party notification
- System monitoring alerts
- External threat intelligence

Staff reporting procedure:

1. Do not ignore it or try to fix it alone
2. Do not turn off the affected device (preserves evidence)
3. Note the time you discovered it
4. Call IT Manager immediately
5. Complete Incident Report Form
6. Do not discuss on WhatsApp or open email threads

Initial information to capture:

- Date and time of discovery
- Who discovered it and how
- What systems or data are affected
- What actions have already been taken
- Whether the incident is still ongoing

Phase 3 – Assessment And Classification

IT Manager actions within first hour:

1. Receive incident report
2. Gather initial information
3. Classify severity (Tier 1–4) using Classification Guide
4. Notify team members based on tier
5. Open incident log with unique ID
 - Format : INC-YYYY-MM-NNN
 - Example : INC-2026-03-001
6. Assess POPIA reportability with Information Officer
7. If POPIA reportable → Start 72-Hour Clock Immediately
8. Brief CEO if Tier 1 or Tier 2

POPIA clock fields:

Time of discovery: _____

72-hour deadline: _____

Responsible: Information Officer

Escalation if at risk of missing: CEO + Legal

Phase 4 – Containment

Short-term containment (first 4 hours) – stop the bleeding:

- Isolate affected systems from network (unplug cable / disable Wi-Fi)
- DO NOT power off unless instructed – preserves evidence

- Revoke compromised user credentials
- Block suspicious IP addresses on firewall
- Enable additional logging on all systems
- Notify staff not to use affected systems until cleared
- Preserve evidence before making changes
- Screenshot all error messages and alerts
- Do not wipe or rebuild any system yet

Evidence log format (chain of custody):
[TIME] | [WHO] | [ACTION TAKEN] | [OUTCOME]

Example:

[14:32] | IT Manager | Isolated PHRS server by disabling switch port. The system remains powered on. Logs preserved. | Contained

Long-term containment (4–72 hours):

- Deploy additional monitoring
- Implement temporary compensating controls
- Maintain clinical operations using continuity procedures if systems offline
- Prepare clean systems for restoration
- Continue evidence collection

Phase 5 – Eradication And Recovery

Eradication:

- Identify root cause
- Remove malware or attacker access
- Close the vulnerability that was exploited
- Reset all potentially compromised credentials
- Patch affected systems before restoration
- Verify eradication with forensic evidence
- Document all eradication actions

Recovery:

- Restore systems from verified clean backup
- Confirm backup integrity before restoration
- Test restored systems before reconnecting to network
- Monitor restored systems intensively
- Restore services starting with lowest-risk systems first
- Confirm patient record integrity
- Clinical Lead approves return to normal clinical operations
- IT Manager signs off technical recovery
- CEO approves full service restoration

Systems may return to production only when:

- Root cause identified and eliminated
- All malware or attacker access removed
- Systems patched and hardened
- Credentials reset across affected accounts
- Backup integrity confirmed
- Monitoring confirmed active
- Clinical Lead approved return

Phase 6 – Post-Incident Review

Timeline: Within 14 days of incident closure

Attendees: IT Manager, Information Officer, GRC Analyst, CEO (Tier 1), Clinical Lead (if clinical impact)

Questions to answer:

1. What exactly happened and when?
2. How was the incident detected?
3. Was detection fast enough?
4. Were response procedures followed?
5. Was the POPIA timeline met?
6. What evidence was collected well / missed?
7. What would have prevented this?
8. What controls need updating?
9. Were staff communications clear?
10. What training gaps exist?

Required outputs:

- Post-Incident Review Report
- Updated risk register entries
- Corrective action plan with owners and dates
- Policy or procedure updates identified
- Lessons learned documented

GRC Analyst updates the risk register within 7 days of incident closure.

6. Scenario-Specific Procedures**Scenario A :****Ransomware Attack**

Classification : Tier 1 Critical
POPIA Reportable : Yes

Immediate actions (first 30 minutes):

- Do not pay the ransom (CEO + insurer decision only)
- Isolate all systems from the network including clinical workstations
- Disconnect all network shares
- Activate clinical continuity plan (paper records, manual processes)
- Notify CEO and Information Officer
- Start POPIA 72-hour clock
- Call cyber insurer hotline
- Call forensic IR firm
- Preserve ransom note and all screens
- Do not restart any affected machines

Clinical continuity during ransomware:

- Revert to paper prescription pads
- Use offline appointment book
- Defer non-urgent telehealth appointments
- Critical patients seen in person
- Clinical Lead manages patient communications

Recovery sequence:

1. Forensic investigation completed
2. Ransom decision by CEO and insurer
3. Systems rebuilt from clean backups
4. Patient record integrity verified
5. Clinical Lead approves return
6. Intensive monitoring for 30 days

Scenario B

Phishing And Account Compromise

Classification : TIER 1 or 2
POPIA Reportable : ASSESS IMPACT

Immediate actions:

- Revoke compromised account credentials
- Enable MFA on account immediately
- Review all actions taken by account in last 30 days (audit logs)
- Check for email forwarding rules set up by attacker
- Check for new users or admin accounts created during compromise
- Assess what data the account could access
- If patient data accessed: TIER 1 – start POPIA 72-hour clock
- Scan all devices used by that account
- Check other staff for same phishing email
- Block sender and domain in email filter
- Issue staff-wide alert about the phishing method

Signs attacker may still have access:

- Unexpected password reset emails
- Login alerts from unusual locations
- Email rules you did not create
- New admin accounts in the tenant
- Patient records accessed at unusual times

SCENARIO C

STOLEN OR LOST LAPTOP

Classification : Tier 1 if unencrypted
: Tier 2 if encrypted
POPIA Reportable : Yes if unencrypted

Immediate actions:

- Confirm encryption status in asset register
 - BitLocker on lower risk
 - BitLocker off POPIA breach confirmed
- Remotely wipe device via Intune if enrolled in MDM
- Revoke all credentials stored on device
- Identify all patient data accessible from that device
- If unencrypted: Start POPIA 72-hour clock
- Report to SAPS (required for insurance) – get case number
- Notify cyber insurer
- Identify last known location and circumstances
- Review CCTV if available

Note: One encrypted stolen laptop = TIER 2.
One unencrypted stolen laptop = TIER 1 POPIA breach.
This is why BitLocker was the first recommended action in Project 1 and Project 2.

SCENARIO D

POPIA DATA BREACH NOTIFICATION

Classification : Tier 1
Triggered by: : Any confirmed unauthorised access to or loss of personal information

72-Hour Procedure:

Hour 0 – Discovery

- Incident discovered and classified
- Information Officer notified immediately
- 72-hour clock starts NOW
- Record:
 - Discovery time : _____
 - Deadline : _____

HOURL 0–4 – ASSESSMENT

- Confirm what data was affected
- Confirm how many data subjects affected
- Confirm how the breach occurred
- Confirm if breach is ongoing or contained
- Begin preparing notification documents

HOURL 4–24 – PREPARATION

- Complete Form 4 (pre-populated template)
- CEO reviews and approves draft
- Legal counsel reviews if available
- Prepare affected person notification
- Document all containment actions taken

HOURL 24–72 – NOTIFICATION

- Submit Form 4 to Information Regulator:
 - Email: info regulator@info regulator.org.za
 - Portal: info regulator.org.za
- Notify affected data subjects as soon as reasonably possible
- Keep evidence of submission
- Log submission time and confirmation

Form 4 must include:

- Description of the breach
- Date/time of breach and discovery
- Categories of personal information affected
- Approximate number of data subjects
- Likely consequences of the breach
- Measures taken or proposed
- Contact details of Information Officer

After notification:

- Cooperate fully with Information Regulator
- Provide updates as investigation progresses
- Do not destroy any evidence
- Legal counsel present for any meetings

7. KEY CONTACTS – PRINT AND STORE OFFLINE

IT Manager (IR Lead)	: _____
Information Officer	: _____
CEO	: _____
Clinical Lead	: _____
Cyber Insurer Hotline	: _____
Legal Counsel	: _____
Forensic IR Firm	: _____
Microsoft Support	: _____
Information Regulator	: info regulator@info regulator.org.za
Tel	: 012 406 4818
SAPS (stolen devices)	: 10111

Document Control

Prepared by: Patrick Mohlala, GRC Analyst

Version: 1.0

Status: Draft – Pending CEO Approval

Review: March 2027